

Feedback et Correction

Points Positifs :

1. La gestion de la session est correctement initiée avec `session\_start()`.
2. La redirection vers `session.php` après une connexion réussie est bien implémentée.
3. Les liens pour modifier/supprimer dans `affichageAnnuaire.php` utilisent des paramètres GET et une confirmation JS pour la suppression (bonne pratique).

Problèmes Identifiés :

1. **Exercice 3 - Page `login.php` (Partie 1)** :

- **Manque de vérification des identifiants** : Le code stocke directement le login en session sans vérifier le mot de passe ou l'existence de l'utilisateur en BDD.
- **Absence de gestion des erreurs** : Aucun feedback si l'authentification échoue.
- **Faibles de sécurité** : Pas de protection contre les attaques par force brute ou injections SQL.

2. **Exercice 2 - Page `affichageAnnuaire.php`** :

- **Affichage incomplet** : Seul le champ `nom` est affiché, l'énoncé demande tous les champs de la table `annuaire`.
- **Connexion BDD manquante** : La variable `\$pdo` n'est pas définie (fichier `connexion.php` non inclus).
- **Protection d'accès absente** : La page n'est pas réservée aux utilisateurs connectés.

3. **Exercice 3 - Structure globale** :

- **Pages manquantes** : `connexion.php`, `inscription.php`, `deconnexion.php` non fournies.
- **Hachage du mot de passe** : Absent dans l'inscription et la connexion.
- **Vérification d'unicité du login** : Non implémentée.

Correction Détaillée :

1. Correction de `login.php` (Exercice 3) :

```
```php
```

```
<?php
```

```
session_start();
```

```
include 'connexion.php'; // Fichier avec la connexion PDO
```

```
$error = "";
```

```
if (isset($_POST['login'])) {
```

```
 $login = trim($_POST['login']);
```

```
 $password = $_POST['password'];
```

```
 // Vérification des champs vides
```

```
 if (empty($login) || empty($password)) {
```

```
 $error = "Tous les champs sont obligatoires!";
```

```
 } else {
```

```
 // Requête préparée pour éviter les injections SQL
```

```
 $stmt = $pdo->prepare("SELECT * FROM utilisateurs WHERE login = ?");
```

```
 $stmt->execute([$login]);
```

```
 $user = $stmt->fetch();
```

```
 // Vérification du mot de passe haché
```

```

if ($user && password_verify($password, $user['pass'])) {

 $_SESSION['user'] = [

 'id' => $user['id'],

 'nom' => $user['nom'],

 'prenom' => $user['prenom'],

 'login' => $user['login']

];

 header("Location: session.php");

 exit;

} else {

 $error = "Identifiants incorrects!";

}

}

}

?>

```

<!-- Formulaire de connexion -->

<form method="POST">

<input type="text" name="login" placeholder="Login" required>

<input type="password" name="password" placeholder="Mot de passe" required>

<button type="submit">Connexion</button>

<?php if (!empty(\$error)) echo "<p style='color:red;'>\$error</p>"; ?>

</form>

...

#### 2. Correction de `affichageAnnuaire.php` (Exercice 2) :

```
```php
```

```
<?php
```

```
session_start();
```

```
// Vérification de la connexion
```

```
if (!isset($_SESSION['user'])) {
```

```
    header("Location: login.php");
```

```
    exit;
```

```
}
```

```
include 'connexion.php'; // Connexion à la BDD
```

```
// Récupération des données
```

```
$result = $pdo->query("SELECT * FROM annuaire");
```

```
echo "<table border='1'>";
```

```
echo    "<tr><th>ID</th><th>Nom</th><th>Prénom</th><th>Téléphone</th><th>Ville</th><th>Date  
de naissance</th><th>Actions</th></tr>";
```

```
foreach ($result as $row) {
```

```
    echo "<tr>";
```

```
    echo "<td>" . htmlspecialchars($row['id_annuaire']) . "</td>";
```

```
    echo "<td>" . htmlspecialchars($row['nom']) . "</td>";
```

```
    echo "<td>" . htmlspecialchars($row['prenom']) . "</td>";
```

```
    echo "<td>" . htmlspecialchars($row['telephone']) . "</td>";
```

```
    echo "<td>" . htmlspecialchars($row['ville']) . "</td>";
```

```
    echo "<td>" . htmlspecialchars($row['date_de_naissance']) . "</td>";
```

```
    echo "<td>
```

```

        <a href='modifier.php?id=" . $row['id_annuaire'] . "'>Modifier</a> |

        <a href='supprimer.php?id=" . $row['id_annuaire'] . "' onclick='return confirm(\\"Confirmer la
suppression ?\\")>Supprimer</a>

    </td>";

    echo "</tr>";

}

echo "</table>";

?>

...

```

3. Ajouts Critiques :

- ****connexion.php**** (Exercice 3) :

```

```php

<?php

$host = 'localhost';

$dbname = 'BiblioBD';

$user = 'root';

$pass = '';

try {

 $pdo = new PDO("mysql:host=$host;dbname=$dbname;charset=utf8", $user, $pass);

 $pdo->setAttribute(PDO::ATTR_ERRMODE, PDO::ERRMODE_EXCEPTION);

} catch (PDOException $e) {

 die("Erreur de connexion: " . $e->getMessage());

}

?>

```

...

- **\*\*deconnexion.php\*\*** (Exercice 3) :

```
```php
```

```
<?php
```

```
session_start();
```

```
session_destroy();
```

```
header("Location: login.php");
```

```
exit;
```

```
?>
```

```
...
```

Note : 9/20

****Justification**** :

- ****Points acquis**** :

- Structure de base des sessions et redirection (3/20).
- Liens de modification/suppression fonctionnels (2/20).

- ****Manquements majeurs**** :

- Absence de vérification des identifiants en BDD (-4).
- Pages critiques non fournies (inscription, session, etc.) (-3).
- Affichage incomplet de l'annuaire (-2).
- Pas de hachage des mots de passe (-1).
- Vulnérabilités de sécurité non traitées (-1).

****Recommandations**** :

1. Implémenter **l'inscription** avec hachage password (`password_hash()`).
2. Ajouter la vérification d'**unicité du login** lors de l'inscription.
3. Protéger toutes les pages avec `session_start()` + vérification.
4. Utiliser des **requêtes préparées** partout pour éviter les injections SQL.
5. Compléter les pages manquantes (`session.php`, `modifier.php`, etc.).